



Note de cadrage

Module : Wargame

Ce cahier est à destination des stagiaires. Il contient l'ensemble des informations qui vous permettront de créer vos challenges et de répondre aux exigences des challenges attendus.

Table des matières

1. Création du challenge	3
2. Rendu des challenges	5
3. Règle à suivre	6
4. Nomenclature du flag	7
5. Modèle de write up	8
6. Système de notation	9
7. Rendu des challenges	10

1. Création du challenge

Objectif :

Seul ou en équipe de 3 MAX, vous devrez rendre :

- **UN** Challenge CTF
- Le rapport détaillé sur la résolution de celui-ci (WriteUp)

Les challenges devront contenir les informations suivantes :

- Un titre
- Un énoncé
- Un type de challenge (Voir les catégories possibles)
- La difficulté estimée du challenge (Facile / Intermédiaire / Difficile / Insane)
- Contenir un flag qui devra être trouvé (Suivre la nomenclature)

Exemple :

Titre L'image clé
(Intermédiaire)

Difficulté

Vous avez intercepté des échanges entre deux cyberhacktivistes qui projettent d'attaquer la centrale nucléaire de Flamanville en Normandie.

Afin d'échanger la clé du malware qu'ils projettent d'envoyer, ils ont pour habitude de la cacher dans une image.

Votre mission, trouver la clé qui permet de déchiffrer la charge.

Bon chance !

Enoncé

 mot-de-pass...

Les catégories acceptées sont les suivantes :

- **Forensic** : Fichier à investiguer pour trouver le flag
- **Cryptographie** : Déchiffrer une donnée en exploitant des faiblesses crypto
- **Reverse** : Binaire / Script à reverser pour obtenir le flag
- **Réseau** : Capture réseau à investiguer / manipuler pour obtenir le flag
- **Web** : Application ou service web vulnérable contenant un flag
- **Pentest** : VM à rooter pour obtenir le flag

Un challenge peut contenir plusieurs catégories

Les échelles de difficultés sont les suivantes :

- **Facile** (Tout niveau) 100 pts
- **Intermédiaire** (Base requise) 200 pts
- **Difficile** (Connaissance solide sur le sujet) 300 pts
- **Insane** (Maîtrise complète et poussée du sujet) 500 pts

2. Rendu des challenges

Pour certaines catégories, vous rendrez vos fichiers dans le format suivant :

▣ Pour les challenges Web

Vous rendrez la machine virtuelle prévu pour la semaine de résolution

Dans le cas d'une image docker, **vous rendrez le dockerfile** avec les composants et configurations de l'application (pour l'intégration à la plateforme en ligne) :

▣ Pour les challenges sous forme de fichier ou contenant un malware

Zippez le challenge avec un mot de passe (pour éviter la suppression des données par l'antivirus google)

▣ Pour les challenges de type Pentest

Vous fournirez la machine virtuelle en **OVA** créé avec **virtualbox** (Format du disque virtuel : **VMDK**)

Le réseau de la VM doit être en **bridge** et l'IP en **DHCP**

Pour les systèmes linux vous ajouterez le fichier **/etc/issue** suivant :

```
Address : \4{eth0}    # Changer avec le nom de l'interface réseau
root : mdp           # Changer avec le mdp root
```

N'oubliez pas de restreindre les droits dessus :

```
chown root:root /etc/issue
chmod 700 /etc/issue
```

3. Règle à suivre

Plusieurs règles durant la création du challenge doivent être respectés pour **éviter l'infaisabilité du challenge** :

- Pas de guessing, devinette, charade, etc ...
- Pas d'IPS, blocage d'IP, blocage de port, ... (fail2ban, portsentry, portknocking, ...)
- En cas de bruteforce, le mot de passe doit être dans rockyou.txt (évitez les mots de passe en fin de wordlist)
- Si le joueur doit créer sa propre wordlist, vous devez laisser des indices obligatoires sur la forme du mot de passe à trouver
- Dans le cas d'un challenge OSINT, Veillez à ce que les sources de données gardent l'information à vie (Exemple reddit, twitter, pastebin) afin d'éviter que le challenge ne soit plus fonctionnel quelques temps après la création
- Utiliser des références à ESD Academy (Fond d'écran ESD, groupe, images, etc)
- **PAS DE STEGANOGRAPHIE ni d'OSINT**

4.Nomenclature du flag

Le flag devra suivre la forme suivante :

ESD{XXXXXXXX}

Il peut s'agir d'une chaîne de caractères, d'un mot de passe, d'un hash, d'une IP, d'un nom, etc ... (Tout dépendra de ce que le joueur doit trouver dans l'histoire du challenge) **Indiquez de quoi il s'agit dans l'énoncé**

Conforme :

ESD{G00d_G4me_Y0u_W1n}
ESD{P@\$w0rd}
ESD{mrrobot35@hacking.net}

- Lorsque le flag est la concaténation de plusieurs mots à trouver, vous devrez **indiquer la forme dans l'énoncé**

Exemple :

Le flag est la concaténation de l'IP le port et le processus du malware : ESD{IP_PORT_PROCESSUS}

Certaines formes de flags sont interdites, certains caractères ou informations sont à bannir

- Les **espaces sont interdits** dans le flag
- Pas d'**informations personnelles** d'une personne existante
- Le flag ne **doit pas être une commande utile pour la résolution**

Non conforme :

ESD{sqlmap -u 'https://vm.fr/id=1' -M POST -d}

Attention la validation du flag sera sensible à la casse, n'oubliez pas de bien respecter la casse dans le fichier du flag (Majuscule, chiffre, symbole, etc ...)

5. Modèle de write up

Votre Write Up devra contenir :

- Votre réflexion sur la résolution des étapes
- Des captures d'écran et explications
- Les commandes / outils ou script utilisées durant la résolution

Votre WriteUp doit être **reproductible** par le lecteur

Un **exemple de Write UP est en annexe** (*Sample_Write_Up.pdf*)
Inspirez-vous en.

D'autres exemples sont disponibles sur Internet

Vous utiliserez le modèle « **Write_Up.docm** » fourni dans l'ENT pour rédiger votre WriteUp et la description de votre challenge

Write Up

Promotion	RES001
Nom	Khalifa
Prénom	Jeremy
Pseudo	K-ifa
Acceptez-vous que votre pseudo soit inscrit dans l'énoncé comme signature ?	☒ Oui ☐ Non

Description Challenge

Titre	Catch the cheater
Type	Forensic
Difficult�	Moyen
Flag	ESD{Trich3r C NULL}

Enoncé :

Un stagiaire a trouvé le moyen de tricher aux examens ESD, celui-ci a révélé la méthode aux étudiants.

Nous avons intercepté des échanges réseaux dans lesquels nous le soupçonnons d'avoir envoyé son mode opératoire

Retrouvez sa procédure pour pouvoir patcher la faiblesse et empêcher les stagiaires de tricher !

Le flag se trouve dans le fichier de procédure

Write Up

Un pcap nous est fourni, celui-ci contient principalement des paquets TCP et quelques ICMP et DNS

La quantité des échanges TCP attire notre attention :

The screenshot shows the Wireshark interface with the 'Statistics' pane on the right. The 'Packet List' pane shows a list of captured packets. The 'Packet Details' pane shows the details of the selected packet (No. 11), including 'Ethernet II', 'Internet Protocol Version 4', 'Transmission Control Protocol', and 'Hypertext Transfer Protocol'.

No.	Time	Source	Destination	Protocol	Length	Info
0	0.000000	192.168.1.1	192.168.1.2	ICMP	60	Echo (ping) 60 bytes of data
1	0.000000	192.168.1.2	192.168.1.1	ICMP	60	Echo (ping) 60 bytes of data
2	0.000000	192.168.1.1	192.168.1.2	ICMP	60	Echo (ping) 60 bytes of data
3	0.000000	192.168.1.2	192.168.1.1	ICMP	60	Echo (ping) 60 bytes of data
4	0.000000	192.168.1.1	192.168.1.2	ICMP	60	Echo (ping) 60 bytes of data
5	0.000000	192.168.1.2	192.168.1.1	ICMP	60	Echo (ping) 60 bytes of data
6	0.000000	192.168.1.1	192.168.1.2	ICMP	60	Echo (ping) 60 bytes of data
7	0.000000	192.168.1.2	192.168.1.1	ICMP	60	Echo (ping) 60 bytes of data
8	0.000000	192.168.1.1	192.168.1.2	ICMP	60	Echo (ping) 60 bytes of data
9	0.000000	192.168.1.2	192.168.1.1	ICMP	60	Echo (ping) 60 bytes of data
10	0.000000	192.168.1.1	192.168.1.2	ICMP	60	Echo (ping) 60 bytes of data
11	0.000000	192.168.1.2	192.168.1.1	TCP	60	Reset Seq=1000000000
12	0.000000	192.168.1.1	192.168.1.2	ICMP	60	Echo (ping) 60 bytes of data

Wireshark -> statistiques -> Hiérarchie des protocoles

Les plus gros échanges ont été fait entre 51.75.140.195 et 5.62.41.128

[illegible]

Wireshark -> statistiques -> Conversation

On constate que 5.62.41.128 à envoyé la première connexion (FLAG TCP SYN) sur le port 666 de 51.75.140.195

Year	Age	Gender	Marital Status	Education	Occupation	Income	Assets	Liabilities	Net Worth	Debt-to-Income Ratio	Debt-to-Assets Ratio	Debt-to-Net Worth Ratio
2019	30	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2020	31	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2021	32	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2022	33	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2023	34	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2024	35	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2025	36	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2026	37	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2027	38	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2028	39	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2029	40	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2030	41	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2031	42	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2032	43	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2033	44	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2034	45	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2035	46	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2036	47	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2037	48	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2038	49	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2039	50	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2040	51	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2041	52	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2042	53	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2043	54	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2044	55	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2045	56	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2046	57	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2047	58	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67
2048	59	Male	Married	High School	Unemployed	\$15,000	\$10,000	\$5,000	\$5,000	0.33	0.20	0.67

6. Système de notation

Votre note sera en 2 parties :

1ere partie (sur 10)

Vous serez évalué sur la qualité et la réflexion de votre challenge (Plus il est original plus la note sera élevée), l'effort et l'investissement rapportent également des points.

La qualité de votre WriteUp comptera également beaucoup (Plus il est complet, propre et lisible, plus vous aurez une note élevée)

Note: Un challenge poussé avec un Write up incompréhensible ou incomplet ne rapportera pas beaucoup de points (et inversement) Soyez rigoureux

La plateforme esd.ctfd.io peut vous donner des exemples de challenges ayant été apprécié.

Si votre challenge séduit les formateurs, il sera intégré à la plateforme

2eme partie (Sur 10)

Vous serez évalué sur le nombre de challenge résolue la semaine wargame
(Plus votre score sera haut, plus votre note le sera)

7. Rendu des challenges

Vous rendrez le tout sur la **classroom** dans l'exercice « **Rendu Challenge Wargame** » du module Wargame

M04-Wargame

 Rendu Challenge Wargame

Date limite : 17 oct. 2021 23:...

Date de publication : 13:29 (Modification : 13:31)

Vous rendrez ici :

- Une archive / Zip contenant votre challenge
- Le Writeup
- La fiche de rendu (dispo sur ENT)

0

Remis

8

Attribués

Votre rendu devra finalement contenir :

- **Write Up** (basé sur le document Write_Up.docm disponible sur ENT)
- **Un zip** contenant vos fichiers de challenge (et composants dans le cas d'une appli web)

Note : Il est conseillé de chiffrer le ZIP et de fournir le mot de passe en description pour éviter que Google ou l'antivirus ne supprime des fichiers cachés ou malveillant

 Rendu Challenge Wargame

Glenn Le Gac • 11 févr. 2019

Commentaires ajoutés au cours



Ajouter un commentaire au cours...



Votre devoir

Devoir attribué

 Chall_Jkhalfa.zip

Archive compressée



 Write_Up_JKHALF...

PDF



+ Ajouter ou créer

Rendre le devoir

Commentaires privés



Password : azerty



Module Wargame